

Soupedecode — AD Compromise Walkthrough

Red Team Attack Chain · Blue Team Detection · Mitigations

This document traces a full Active Directory domain compromise from initial recon to SYSTEM shell, with detection and mitigation guidance at each stage. Target: DC01.SOUPEDECODE.LOCAL (Windows Server 2022).

Attack Chain Summary

Step	Technique	Outcome
1	Nmap port scan	Confirmed AD DC, domain name, OS
2	SMB null session share listing	Found non-default 'backup' share
3	Kerberos username enumeration (Kerbrute)	Found: admin, charlie
4	Password spray / guest SMB	Creds: ybob317:ybob317
5	SMB Users share browsing	Retrieved user flag
6	SYSVOL/GPO exploration	No GPP creds found (dead end)
7	Kerberoasting (GetUserSPNs.py)	5 TGS hashes; cracked file_svc>Password123!!
8	Backup share access as file_svc	Found NTLM hash dump (backup_extract.txt)
9	Pass-the-Hash (CrackMapExec)	FileServer\$ hash = local admin on DC01
10	psexec/wmiexec Pth shell	SYSTEM shell → root flag

Step 1 — Network Recon (Nmap)

■ Attacker Action

Full TCP scan revealed open ports: 53, 88 (Kerberos), 135, 139, 389 (LDAP), 445 (SMB), 3268, 3389 (RDP). RDP banner leaked domain name SOUPEDECODE.LOCAL, hostname DC01, and OS version Windows Server 2022.

```
nmap -sC -sV -p- <target>
```

■ Blue Team: Detection

IDS/IPS should alert on SYN scans from external/untrusted hosts. Windows Firewall logs and network flow data will show sequential port probing. Sentinel/Splunk rule: >20 distinct ports from one host in 60s.

Mitigation: Restrict RDP/SMB/LDAP to trusted networks. Disable RDP NTLM info leakage where possible. Segment DCs from general network access.

Step 2 — SMB Null Session Share Enumeration

■ Attacker Action

smbclient -L with no credentials (-N) listed all share names including the custom 'backup' share. Null session was sufficient to enumerate share names but not to read contents.

```
smbclient -L //<target>/ -N
```

■ Blue Team: Detection

Windows Security Event 5140 (share accessed) and 5145 (share object checked) log anonymous SMB access. Alert on Event 5140 where Subject Account Name = ANONYMOUS LOGON.

Mitigation: Set 'Network access: Shares that can be accessed anonymously' GPO to empty. Disable SMBv1. Set RestrictNullSessAccess=1 in registry.

Step 3 — Kerberos Username Enumeration (Kerbrute)

■ Attacker Action

Kerbrute exploits the difference in Kerberos error codes: valid usernames return KDC_ERR_PREAUTH_REQUIRED, invalid ones return KDC_ERR_C_PRINCIPAL_UNKNOWN. No authentication needed. Found: admin, charlie.

```
kerbrute userenum -d SOUPEDECODE.LOCAL --dc <target> names.txt
```

■ Blue Team: Detection

Event ID 4768 (TGT request) with Result Code 0x6 (user not found) vs 0x18 (bad password) pattern. High volume of 4768 failures from one IP in short time = enumeration. Alert threshold: >50/min.

Mitigation: Enable Kerberos pre-authentication for all accounts (default, don't disable). Rate-limit or geo-block Kerberos from untrusted IPs. Use honeypot usernames in lists.

Step 4 — Credential Discovery (Password Spraying / Guest Auth)

■ Attacker Action

CrackMapExec with --rid-brute and null creds was denied. However, spraying common weak passwords against known users via SMB found ybob317:ybob317 (username = password). This gave READ access to Users, NETLOGON, and SYSVOL shares.

```
crackmapexec smb <target> -u users.txt -p passwords.txt
```

■ Blue Team: Detection

Event 4625 (failed logon) with Logon Type 3 (network) and multiple accounts = spray pattern. Success after failures = Event 4624. Alert: >5 failures across >3 accounts in 2 minutes from one IP. Also alert on ybob317 authenticating from an unexpected IP.

Mitigation: Enforce strong password policy (min 12 chars, complexity). Enable Fine-Grained Password Policies. Deploy Azure AD Password Protection to block weak/common passwords. Enable MFA.

Step 5 — User Flag via SMB (Users Share)

■ Attacker Action

With ybob317 credentials, browsed \\DC01\Users\ybob317\Desktop\ and retrieved the user flag file. The DC was sharing user profile directories over SMB — a common lab/misconfiguration.

■ Blue Team: Detection

Event 5145 logs file-level access on shares. Alert on sensitive file reads (*.txt on Desktop) by accounts that don't normally access that path, especially from non-corporate IPs.

Mitigation: Don't share user profiles over SMB on DCs. Apply NTFS ACLs so users can only access their own folders. Audit read access on sensitive directories.

Step 6 — SYSVOL / GPO Credential Search

■ Attacker Action

Explored SYSVOL for Groups.xml (GPP passwords) and logon scripts. Both Policy folders contained no Preferences\Groups\Groups.xml. Scripts folder was empty. Dead end — but a common high-value target.

```
smbclient //<target>/SYSVOL -U user → navigate to Policies\{GUID}\MACHINE\Preferences\Groups
```

■ Blue Team: Detection

Event 5145 on SYSVOL with access to Preferences\Groups\Groups.xml is a high-fidelity IoC for GPP hunting. Alert on any non-DC reading Groups.xml.

Mitigation: Run Microsoft's Remove-GPPPassword tool. Ensure no cpassword fields exist in SYSVOL. KB2962486 patches GPP password creation in new GPOs (but doesn't remove existing ones).

Step 7 — Kerberoasting

■ Attacker Action

GetUserSPNs.py requested TGS tickets for 5 service accounts with SPNs (file_svc, firewall_svc, backup_svc, web_svc, monitoring_svc). These tickets are encrypted with the service account's NTLM hash and can be cracked offline. file_svc cracked to Password123!! using rockyou.txt in ~52 seconds.

```
python3 GetUserSPNs.py -request 'DOMAIN/user:pass' → hashcat -m 13100 hashes.txt rockyou.txt
```

■ Blue Team: Detection

Event 4769 (TGS request) with Ticket Encryption Type 0x17 (RC4) is the key signal — modern accounts use AES (0x12/0x18). Multiple 4769 events with RC4 for different SPNs in quick succession = Kerberoasting. Alert: >3 RC4 TGS requests from one account in 60s.

Mitigation: Set service account passwords to 25+ random chars (use MSAs/gMSAs — they auto-rotate). Enable AES-only encryption on service accounts. Audit all accounts with SPNs regularly.

Step 8 — Sensitive Data in Backup Share

■ Attacker Action

file_svc credentials granted access to the 'backup' share (previously unreadable). Inside was backup_extract.txt — a NTLM hash dump containing machine account hashes for ~10 servers (WebServer\$, FileServer\$, etc.) in secretdump format.

■ Blue Team: Detection

Event 5145 on the backup share with file_svc account reading .txt files is suspicious. DLP rules should alert on files containing patterns matching NTLM hash format (32-char hex strings with ::: suffix). Alert on service accounts accessing shares outside their normal behaviour baseline.

Mitigation: Never store credential dumps/backups on accessible network shares. Encrypt backup files. Restrict share access to backup service accounts only, via NTFS ACLs. Rotate machine account passwords regularly.

Step 9 — Pass-the-Hash (PtH)

■ Attacker Action

CrackMapExec sprayed the extracted machine account NTLM hashes against DC01 using PtH (no plaintext password needed — NTLM auth uses the hash directly). FileServer\$'s hash authenticated successfully with local admin rights on DC01, returning 'Pwn3d!'.

```
crackmapexec smb <target> -u 'FileServer$' -H <nthash> --local-auth
```

■ Blue Team: Detection

Event 4624 with Logon Type 3, NTLM authentication, and machine account name (ending in \$) from a non-domain-joined host is suspicious. Alert on machine accounts authenticating interactively or to SMB from unexpected source IPs.

CrackMapExec also sets a recognizable user-agent in SMB negotiation.

Mitigation: Enable Protected Users security group for privileged accounts (disables NTLM). Deploy Credential Guard to protect NTLM hashes in memory. Enable SMB signing (already enabled here — didn't prevent PtH but prevents relay). Tier your admin model: machine accounts should never have DC admin rights.

Step 10 — Remote Shell & Root Flag (psexec/wmiexec)

■ Attacker Action

Used impacket psexec or wmiexec with the FileServer\$ hash to get a SYSTEM-level shell on DC01. Navigated to C:\Users\Administrator\Desktop\root.txt for the final flag.

```
impacket-psexec -hashes :<nthash> 'DOMAIN/FileServer$@<target>'
```

■ Blue Team: Detection

psexec creates a random-named service (Event 7045) and drops a binary to ADMIN\$. wmiexec uses WMI (Event 4688 with parent WmiPrvSE.exe, plus WMI activity Event 5861). Both generate Event 4624 (Logon Type 3) and 4672 (special privileges). Alert: service creation by machine account + SYSTEM shell = critical severity.

Mitigation: Implement tiered admin model (Tier 0 = DC only). Use PAWs for admin tasks. Enable Windows Defender Credential Guard. Deploy Microsoft ATA/Defender for Identity — it has specific detections for PtH, Kerberoasting, and reconnaissance.

Key Lessons

Weakness	Impact
Anonymous SMB share listing enabled	Attacker enumerated attack surface without credentials
Username = Password (ybob317:ybob317)	Trivial credential — full share access gained

Service account with weak password + SPN	Kerberoasting → cracked in <1 minute
NTLM hash dump stored on network share	Lateral movement enabled without cracking
Machine account with DC admin rights	Full domain compromise via Pass-the-Hash
No MFA on any account	No secondary barrier at any stage

Tools used: nmap · smbclient · Kerbrute · CrackMapExec · rpcclient · ldapsearch · GetUserSPNs.py (impacket) · hashcat ·
impacket-psexec/wmiexec